

Access Control Scenarios: Real-World Patterns

Combine Entra ID, RBAC, and Azure Policy to solve real enterprise access problems

 Intermediate

 20 Minutes

 AZ-104 · Module 01

Why This Matters

Understanding RBAC, Entra ID, and Policy in theory is one thing. Knowing how to combine them to solve real business problems is another. This doc walks through enterprise scenarios you'll actually encounter: delegating admin duties, securing development environments, controlling costs, enforcing compliance.

Before You Start

Prerequisites	Entra ID Overview, RBAC Fundamentals, Management Groups & Policy
Time to understand	20 minutes
Difficulty	 Intermediate (combines multiple identity concepts)
What you'll learn	How to architect identity/access for real organizations

Scenario 1: Delegating Department Admin Duties

The Problem

TechCorp has:

- Finance department (30 people, their own subscriptions)
- Engineering department (50 people, their own subscriptions)

- Operations (20 people, shared infrastructure)

Goal: Finance VP can manage Finance Azure, but NOT see Engineering. Vice versa. Central IT keeps overall control.

Architecture Solution

Step 1: Create Management Groups by Department

```
Root (TechCorp)
├── Finance Department (MG)
│   ├── Finance-Prod (Subscription)
│   ├── Finance-Dev (Subscription)
│   └── Finance-Backup (Subscription)
├── Engineering Department (MG)
│   ├── Eng-Prod (Subscription)
│   ├── Eng-Dev (Subscription)
│   └── Eng-Test (Subscription)
└── Operations (MG)
    ├── Ops-Infra (Subscription)
    └── Ops-Network (Subscription)
```

Step 2: Create Entra Groups

```
grp-finance-admins
├── Members: Finance VP, Finance team leads
└── Purpose: Finance management

grp-engineering-admins
├── Members: Engineering VP, Engineering team leads
└── Purpose: Engineering management

grp-operations-admins
├── Members: Ops director, senior ops engineers
└── Purpose: Infrastructure management
```

Step 3: Assign RBAC Roles by Management Group

```
Finance Management Group:
  Role: Contributor
  Assigned to: grp-finance-admins
```

Scope: Finance Management Group (applies to all Finance subscriptions)

Result: Finance team can create/modify resources in Finance only

Engineering Management Group:

Role: Contributor

Assigned to: grp-engineering-admins

Scope: Engineering Management Group

Result: Engineering team can create/modify in Engineering only

Root Level:

Role: Owner

Assigned to: grp-operations-admins

Scope: Root (all subscriptions)

Result: IT has full control everywhere

Result

Finance VP logs in

- | Can see Finance subscriptions ✓
- | Can create/modify Finance resources ✓
- | Cannot see Engineering subscriptions X
- | Cannot access Operations X
- └ Billing isolated by department ✓

Engineering VP

- | Can see Engineering subscriptions ✓
- | Can create/modify Engineering resources ✓
- | Cannot see Finance subscriptions X
- └ Complete isolation achieved ✓

IT Director

- | Can see ALL subscriptions ✓
- | Can manage everything ✓
- └ Central oversight maintained ✓

Scenario 2: Securing Development vs. Production

The Problem

TechCorp's DevOps team:

- 10 junior developers (low trust, learning)
- 5 senior developers (high trust, ship code)
- Need to prevent accidents: "Don't delete prod database by mistake"

Goal: Juniors can experiment in Dev, not touch Production.

Architecture Solution

Step 1: Create Subscriptions by Environment

Subscriptions:

- └ Dev (dev-team can play here)
- └ Staging (vetted changes only)
- └ Prod (locked down, seniors only)

Step 2: Create Entra Groups

grp-junior-developers

- └ Members: 10 junior devs
- └ Purpose: Dev environment learning

grp-senior-developers

- └ Members: 5 senior devs
- └ Purpose: All environments, ship code

grp-devops-engineers

- └ Members: 2 DevOps engineers
- └ Purpose: Deployment and infrastructure

Step 3: Create Resource Groups with Scoped Access

DEV Subscription:

Resource Groups: rg-web-dev, rg-api-dev, rg-db-dev

Role: Contributor

Assigned to: grp-junior-developers

Result: Juniors can create/delete freely in Dev ✓

STAGING Subscription:

Role: Contributor

Assigned to: grp-senior-developers + grp-devops-engineers

Result: Only seniors/DevOps can touch staging ✓

PROD Subscription:

Role: Reader

Assigned to: grp-senior-developers + grp-junior-developers

Result: Everyone can VIEW prod, but only DevOps can modify ✓

Role: Contributor

Assigned to: grp-devops-engineers

Result: Only DevOps can change production ✓

Step 4: Add Policies to Production

Policy 1: "All PROD resources must have 'backup' tag set to 'enabled'"

Action: Deny resources without tag

Result: No backup-less prod resource can be created ✓

Policy 2: "Prevent deletion of production databases"

Action: Deny delete operations on SQL databases in PROD

Result: Even DevOps must explicitly override this (audit trail) ✓

Policy 3: "All PROD VMs must use premium disks"

Action: Deny VM creation with standard disks

Result: Enforce performance standards ✓

Result

Junior Developer

└ Dev: Full access (create, modify, delete) ✓

└ Staging: Read-only ✓

- └─ Prod: Read-only, can't change anything ✓
- └─ Safe to experiment without breaking prod ✓

Senior Developer

- └─ Dev: Full access ✓
- └─ Staging: Full access ✓
- └─ Prod: Read-only (change via DevOps) ✓
- └─ Peer review forced before prod changes ✓

DevOps Engineer

- └─ All subscriptions: Full access ✓
- └─ Prod changes: Recorded in audit logs ✓
- └─ Prod safety policies: Can override but traced ✓
- └─ Full control with full accountability ✓

Scenario 3: Cost Control & Chargeback

The Problem

TechCorp's CFO says:

- "We're spending \$50K/month on Azure, but we don't know who's spending what"
- "Engineering says they need expensive VM types, but are they really using them?"
- "We need to prevent runaway spending"

Goal: Enforce cost controls, track spending by department, prevent expensive mistakes.

Architecture Solution

Step 1: Use Tags for Cost Allocation

- All resources must have tags:
- └─ CostCenter: Finance, Engineering, Operations
 - └─ Environment: Dev, Staging, Prod

- └ Owner: Department head email
- └ Project: Name of the project/app

Step 2: Enforce Tags with Policy

Policy: "All resources must have CostCenter tag"

Action: Deny resources without CostCenter

Result: Can't spin up resources without charging them ✓

Policy: "All resources must have Owner tag"

Action: Deny resources without Owner

Result: Know who to ask about each resource ✓

Step 3: Use Azure Policies to Prevent Expensive Choices

Policy: "Only allow Standard_B and Standard_D VM sizes"

Action: Deny Premium VM creation

Result: Prevent expensive mistakes, force justification for exceptions ✓

Policy: "Limit storage redundancy to LRS/ZRS only"

Action: Deny GRS/RA-GRS unless explicitly approved

Result: Prevent unintended expensive replication ✓

Policy: "Only allow certain regions (cost optimization)"

Action: Deny resources in expensive regions

Result: "Tier 1" regions only unless justified ✓

Step 4: Create Cost Anomaly Alert

Azure Cost Management Alert:

- └ Alert when: Cost exceeds budget by 10% in any subscription
- └ Owner: Finance team
- └ Action: Auto-investigate, notify department head

Result

Monthly spending tracking

- └ Finance Department: \$5K (Dev/Prod accounted for)
- └ Engineering Department: \$30K (broken down by project)
- └ Operations: \$15K (infrastructure/shared)
- └ Total: \$50K with full visibility ✓

Developer tries to create expensive VM

- └ Selects Premium_D64s_v3
- └ Policy blocks: "Not in allowed list"
- └ Must request exception (creates audit trail)
- └ Finance reviews justification
- └ If approved, cost charged to project/department ✓

Month-end

- └ CFO sees exact spend per department ✓
- └ Can show Finance: "You used \$5K on these 12 resources"
- └ Can challenge Engineering: "Why did you spin up expensive VMs?"
- └ Full accountability achieved ✓

Scenario 4: Compliance & Audit Requirements

The Problem

TechCorp's compliance officer says:

- "We need audit trail of who accessed what"
- "All data must be encrypted at rest"
- "All data must only exist in US regions"
- "We need SOC 2 compliance"

Goal: Enforce compliance automatically, not through human checking.

Architecture Solution

Step 1: Create Compliance-Focused Policies

Policy: "All storage accounts must use encryption"

Action: Modify (auto-enable encryption if missing)

Result: Zero unencrypted storage ✓

Policy: "Only allow US regions"

Action: Deny non-US regions

Result: Data residency requirement met ✓

Policy: "All databases must have backup enabled"

Action: Deny DB creation without backups

Result: Recovery guaranteed ✓

Policy: "All VMs must have disk encryption"

Action: Modify (auto-enable if missing)

Result: Encrypted disks everywhere ✓

Step 2: Enable Auditing & Logging

All subscriptions:

- └─ Enable Activity Logs (who did what)
- └─ Enable Diagnostic Settings (resource logs)
- └─ Forward to Log Analytics Workspace
- └─ Set retention to 90 days (compliance requirement)

Step 3: Create Audit Role with Read-Only Access

Entra Group: grp-auditors

- └─ Members: Internal auditors, compliance team
- └─ Role: Reader (read-only across all subscriptions)

Result:

- └─ Auditors can VIEW resources ✓
- └─ Auditors cannot MODIFY anything ✓
- └─ Auditors can query logs for investigation ✓
- └─ Separate audit trail of who audited what ✓

Result

At audit time:

- | Query: "Show me all resources created in Jan-Jun"
- | Result: Complete list with who created them, when ✓
- | Query: "Show me all failed login attempts"
- | Result: Security events visible in Activity Logs ✓
- | Query: "Confirm all storage is encrypted"
- | Result: Policy compliance report shows 100% ✓
- | Query: "Verify all data is in US regions"
- | Result: No resources found outside US ✓
- | SOC 2 audit passes with evidence ✓

Key Patterns

Scenario	Management Group	RBAC	Policy	Audit
Delegate by Dept	By department	Scoped roles per MG	None	Standard logs
Dev vs Prod	By environment	Different roles per sub	Prod-specific rules	Activity logs
Cost Control	By department	Same across depts	Tag enforcement, VM limits	Cost mgmt alerts
Compliance	Central control	Auditors read-only	Encryption, region, backup	Enhanced logging, 90d retention

How This Connects to Other Topics

Related to Module 02-05

- **Identity controls everything:** Every module's security starts with identity/access
- **Policies prevent misconfigurations:** Compliance requirements cascade into policies
- **Audit trails hold people accountable:** Logging enables oversight

Related Labs

- Lab 02: RBAC & Azure Policy
- Lab 03: Management Groups

See It In Action

Related labs:

1. Lab 02: RBAC & Azure Policy
2. Lab 03: Management Groups

Key Takeaways

Summary

- **Delegate strategically** with management groups + scoped RBAC
- **Separate environments** (Dev/Staging/Prod) with different permissions
- **Enforce with policy** (cost, compliance, standards)
- **Audit everything** (who did what, when, why)
- **Tag for accountability** (cost center, owner, project, environment)

Next Steps

1. **Review:** Read this doc (you're here)
2. **Practice:** Apply scenarios in Labs 02-03
3. **Secure:** Read **Identity Best Practices** (hardening tactics)

© 2026 — AZ-104 Learning Hub. For study purposes only.